Introducción 1
Alcance y limitaciones 2
Fase I: reconocimiento y escaneo a IMF 3
OSINT 3
Escaneo 7

Fase II: análisis y explotación en entorno controlado 14
Identificación de la máquina víctima 14
Escaneo Detallado de Puertos 15
Acceso al Servicio Web 16
Escaneo Semiautomático con Nikto 17
Análisis Manual con Burp Suite 17
Obtención de la Flag 1 18
Obtención de la Flag 2 18
Obtención de la Flag 3 19
Obtención de la Flag 4 20
Obtención de la Flag 5 21
Obtención de la Flag 6 22
Escalada de privilegios 23
Obtención de la Flag 7 24
Obtención de la Flag 8 27
Obtención de la Flag 9 27
Conclusión 28
Resumen Ejecutivo 28
Principales hallazgos 28
Conclusión General 29

Introducción

Se ha realizado una auditoría de seguridad dividida en dos fases:

- **Fase I: reconocimiento externo (Caja Negra)**

Se partió exclusivamente del nombre de la organización, aplicando técnicas de OSINT, fingerprinting pasivo.

- **Fase II: análisis en entorno controlado**

Se trabajó sobre una máquina virtual vulnerable proporcionada para el ejercicio, donde se realizaron pruebas de detección de vulnerabilidades, explotación y escalada de privilegios.

Alcance y limitaciones

Alcance Fase I:

- Reconocimiento pasivo
- Identificación de dominios y subdominios
- Fingerprinting

? Análisis de DNS y activos expuestos

Limitaciones Fase I:

- Ataques web
- Explotación de vulnerabilidades
- Escaneos agresivos de aplicaciones
- Uso de herramientas automáticas de explotación

Alcance Fase II:

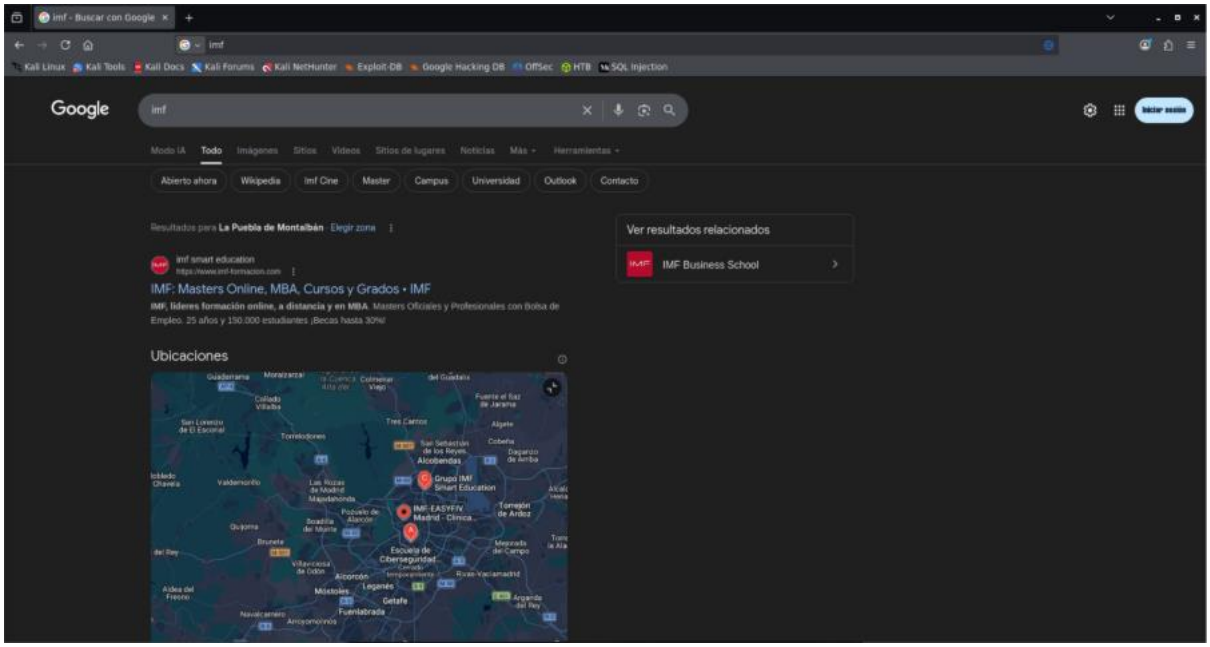
- Escaneo semiautomático de vulnerabilidades

- Verificación manual de hallazgos
- Explotación controlada
- Escalada de privilegios

Fase I: reconocimiento y escaneo a IMF

OSINT

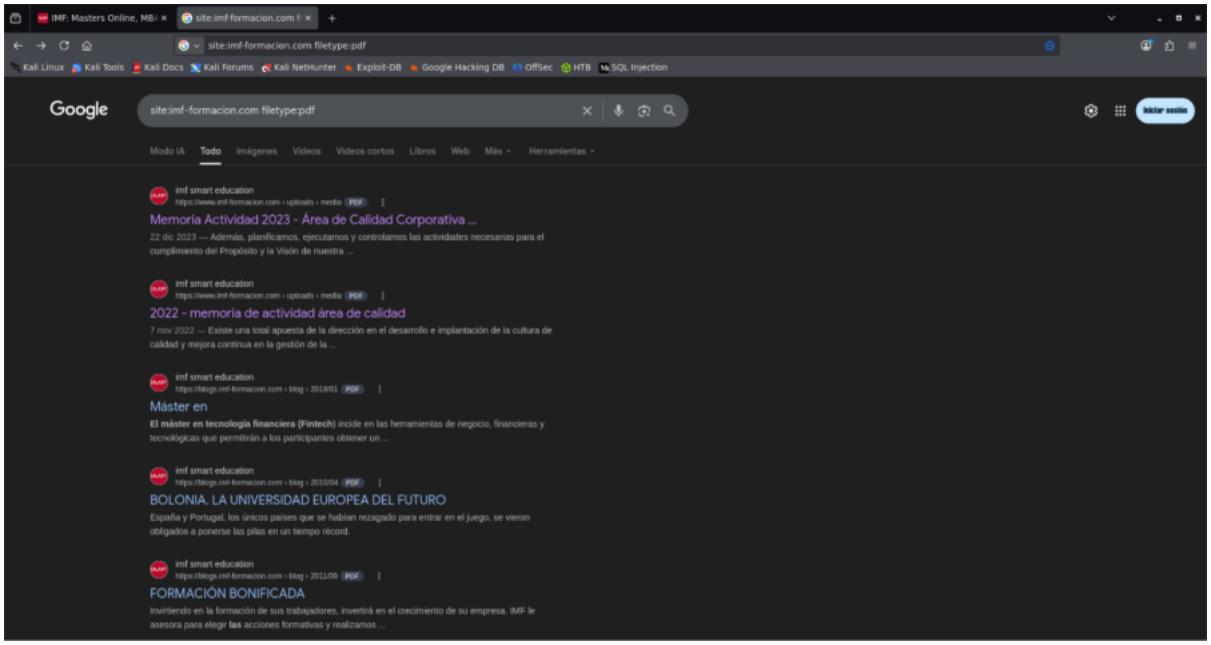
Identificación de la Organización:



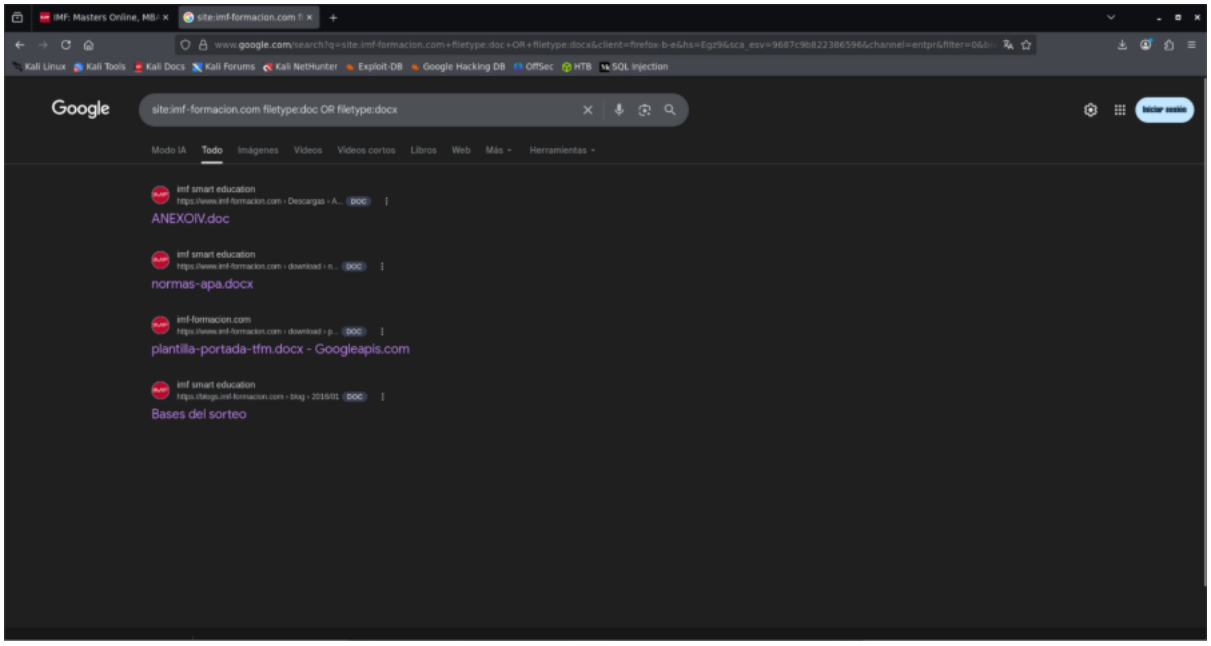
Se realiza una búsqueda en el navegador del nombre de la organización para sacar el dominio principal. En este caso se ve que el dominio es imf-formacion.com

Búsqueda de documentos:

Una vez identificado el dominio, se realizaron búsquedas avanzadas mediante Google Dorks.



En este caso se hace una búsqueda con ‘filetype:pdf’ que es para archivos PDF.

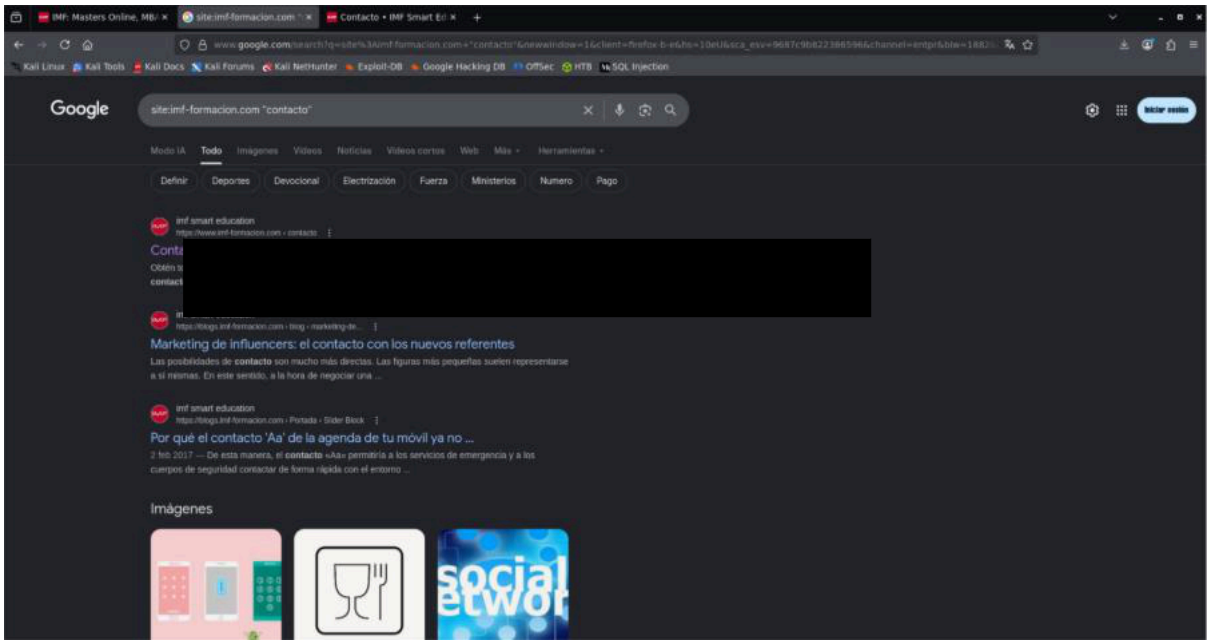


Al igual que en el paso anterior, en esta ocasión se usa ‘filetype:doc OR filetype:docx’ que es para documentos doc y docx.

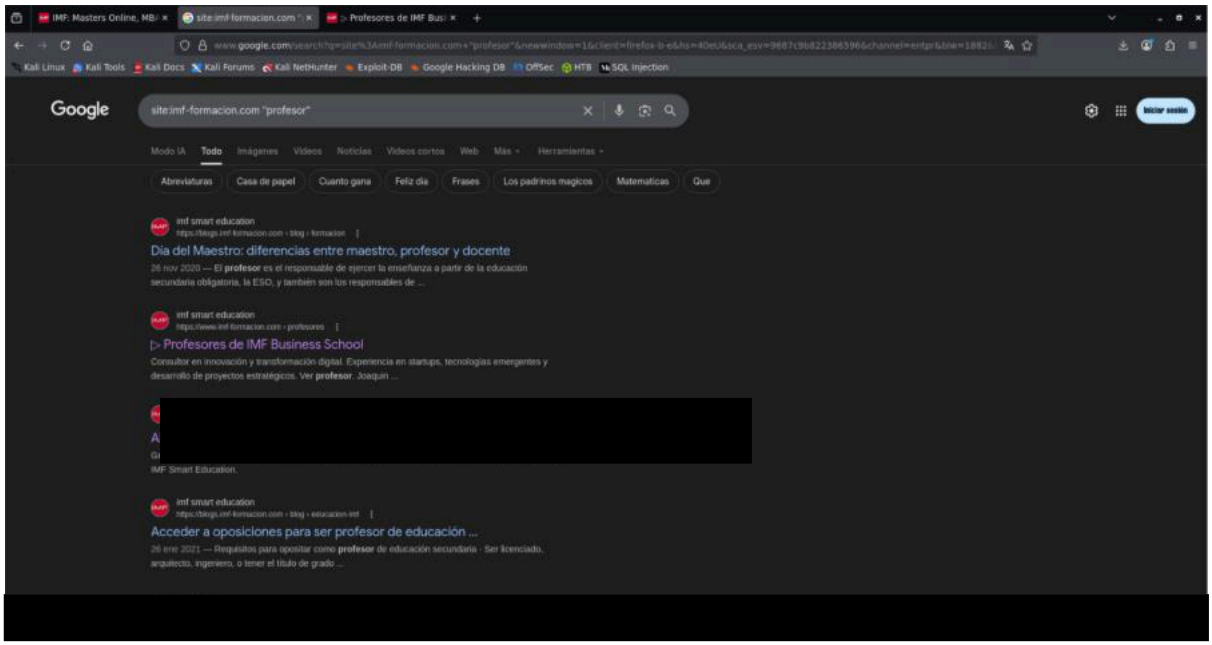
La publicación de documentos puede implicar información como exposición de metadatos, identificación de usuarios internos, información estructural de la organización, etc. Se suelen utilizar herramientas como exiftool, FOCA, etc.

Identificación de empleados:

Una buena información sobre IMF es encontrar a personas relacionadas con ellos, como empleados, soporte, etc. Esto se usa para tener información para ataques tipo phishing.

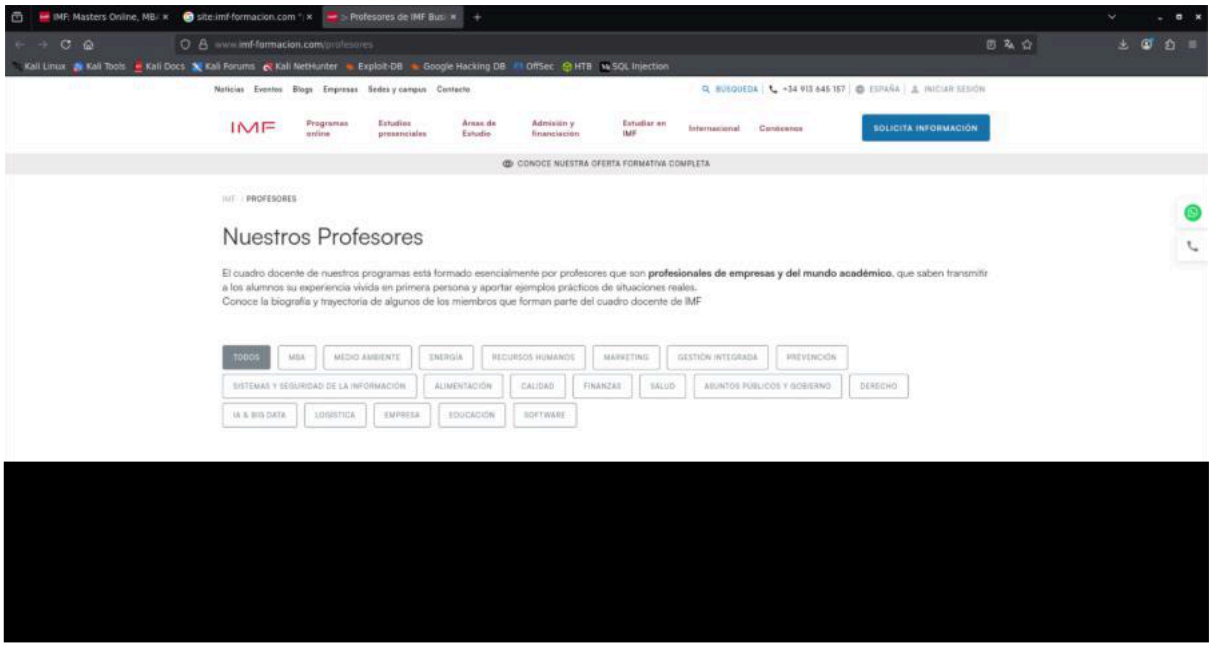


La primera busca será sobre contacto. Esto puede aportar información sobre algún número de teléfono, email de contacto, etc.

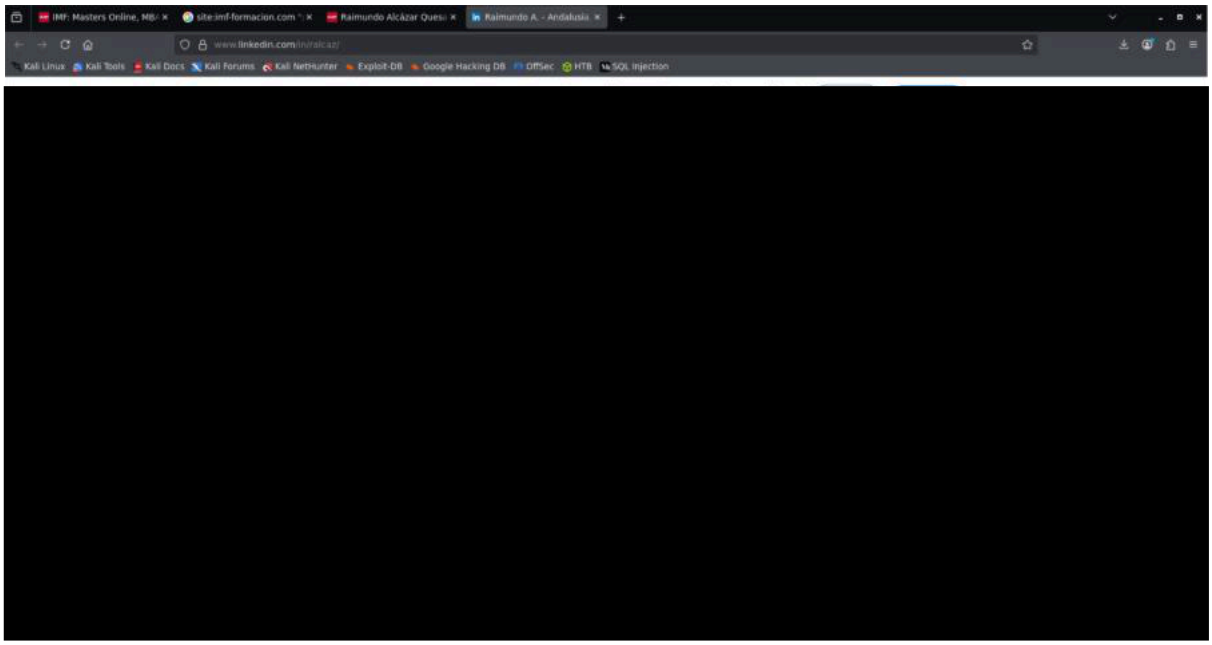


Como se sabe que es una organizacion de másteres profesionales, se tiene

información de que la mayoría de los empleados van a ser profesores. Entonces se hace una búsqueda avanzada sobre ellos.



Con la búsqueda avanzada anterior, se puede ver que hay un apartado de todos los profesores que pertenecen a IMF. Con esto tenemos mucha información y podemos sacar muchos datos sobre ellos.



En el apartado anterior de profesores, cada uno tiene un enlace que lleva directamente a su perfil de LinkedIn. Aquí podemos recoger mucha información de cada uno de ellos

por si se quiere lanzar algún ataque tipo phishing. Aquí se ve el perfil de LinkedIn de [redacted] que es profesor del máster de ciberseguridad.

Escaneo

Información de Red (IPs y DNS):

Una vez se tiene el dominio de IMF y la suficiente información mediante OSINT, se realiza un escaneo del dominio para sacar información de red.

```
❯ nslookup imf-formacion.com
Server:         192.168.226.2
Address:        192.168.226.2#53

Non-authoritative answer:
Name:   imf-formacion.com
[redacted]
```

Con la herramienta nslookup y pasándole el dominio se saca la IP pública que pertenece a dicho dominio. Su IP es [redacted]

```
❯ whois imf-formacion.com
   Domain Name: IMF-FORMACION.COM
   Registry Domain ID: 77881834_DOMAIN_COM-VRSN
   Registrar WHOIS Server: whois.dinahosting.com
   Registrar URL: http://www.dinahosting.com/dominios
   Updated Date: 2020-12-08T06:22:17Z
   Creation Date: 2001-09-27T15:25:06Z
   Registry Expiry Date: 2030-09-27T15:25:06Z
   Registrar: Dinahosting s.l.
   Registrar IANA ID: 1262
   Registrar Abuse Contact Email: abuse-domains@dinahosting.com
   Registrar Abuse Contact Phone: +34.981040200
   Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
   Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
   Name Server: GEORGE.NS.CLOUDFLARE.COM
   Name Server: ROSALYN.NS.CLOUDFLARE.COM
   DNSSEC: unsigned
   URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-02-10T17:14:07Z <<<
```

```
Domain Name: imf-formacion.com
Registry Domain ID: Redacted by Privacy
Registrar WHOIS Server: whois.dinahosting.com
Registrar URL: http://dinahosting.com
Updated Date: 2020-12-08T07:22:17Z
Creation Date: 2001-09-27T15:25:06Z
Registrar Registration Expiration Date: 2030-09-27T15:25:06Z
Registrar: Dinahosting s.l.
Registrar IANA ID: 1262
Registrar Abuse Contact Email: abuse@dinahosting.com
Registrar Abuse Contact Phone: +34.981040200
Domain Status: clientDeleteProhibited (http://www.icann.org/epp#clientDeleteProhibited)
Domain Status: clientTransferProhibited (http://www.icann.org/epp#clientTransferProhibited)
Registrant ID: Redacted for Privacy
Registrant Name: Redacted by Privacy
Registrant Organization: Redacted by Privacy
Registrant Street: Redacted by Privacy
Registrant City: Redacted by Privacy
Registrant State/Province: Madrid
Registrant Postal Code: Redacted by Privacy
Registrant Country: ES
Registrant Phone: Redacted by Privacy
Registrant Email: https://dinahosting.com/dominios/contacto-whois/dominio/imf-formacion.com
Tech ID: Redacted for Privacy
Tech Name: Redacted by Privacy
Tech Phone: Redacted by Privacy
Tech Email: https://dinahosting.com/dominios/contacto-whois/dominio/imf-formacion.com
Name Server: george.ns.cloudflare.com
Name Server: rosalyn.ns.cloudflare.com
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of WHOIS database: 2026-02-10T18:12:37+0100 <<<
```

Con la herramienta whois, se obtiene información sobre el registrador de dominio, fechas de registro y DNS asociados.

```
❯ dig imf-formacion.com

; <<>> DiG 9.20.18-1-Debian <<>> imf-formacion.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 57173
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

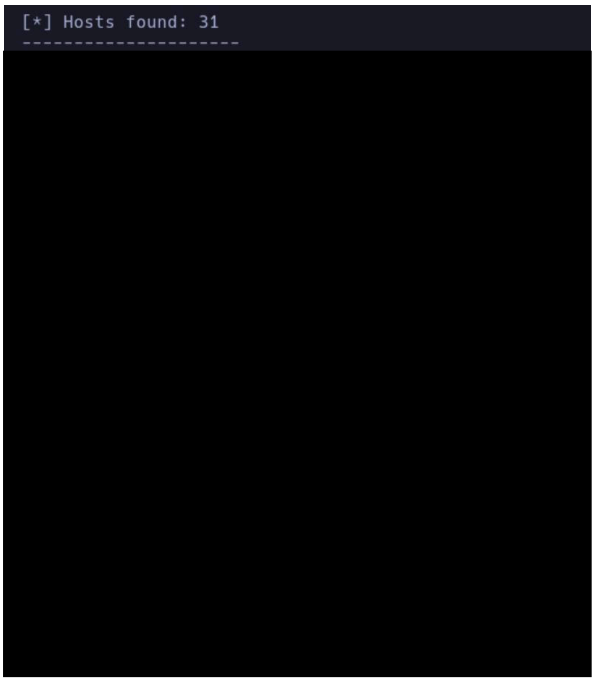
;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; MBZ: 0x0005, udp: 4096
;; QUESTION SECTION:
;imf-formacion.com.             IN      A

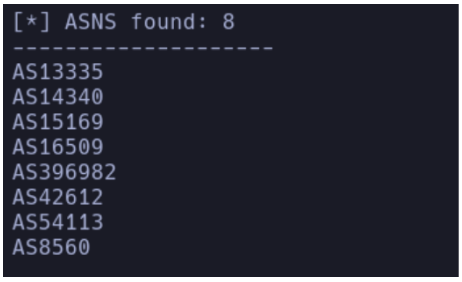
;; Query time: 8 msec
;; SERVER: 192.168.226.2#53(192.168.226.2) (UDP)
;; WHEN: Tue Feb 10 18:18:17 CET 2026
;; MSG SIZE  rcvd: 62
```

La herramienta dig se ha utilizado para realizar consultas DNS sobre el dominio de IMF para obtener información sobre su infraestructura de red. Esta herramienta permite conocer las IP asociadas a un dominio, los servidores DNS y de correo utilizados por la organización, que es útil para identificar activos expuestos y posibles puntos de entrada desde Internet.

Dominios y Correos:



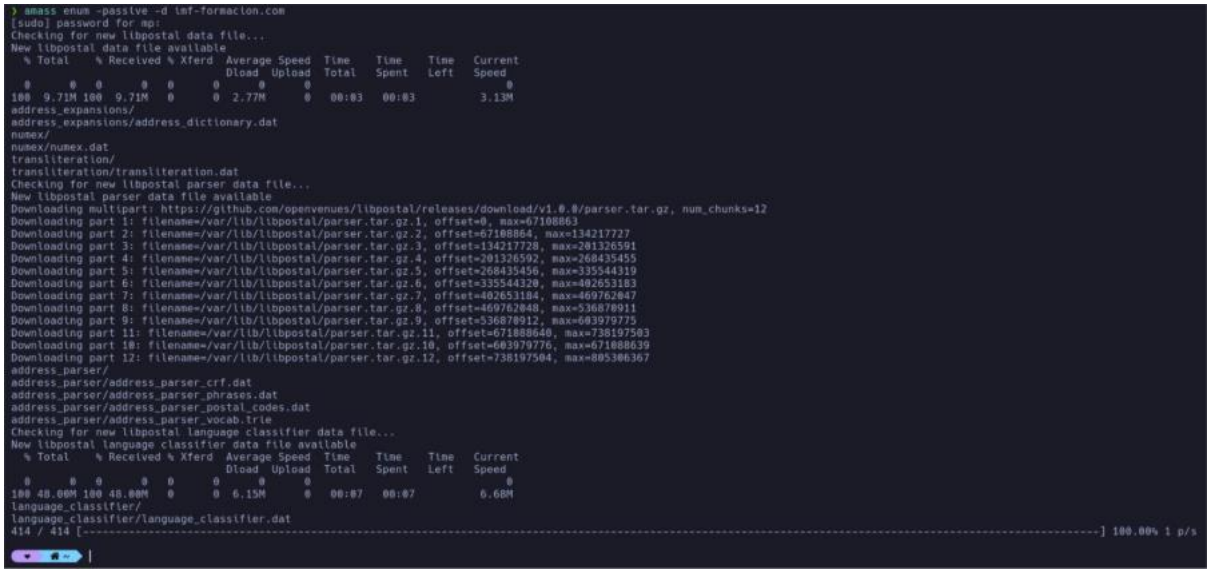






La herramienta theHarvester se ha utilizado con el objetivo de recopilar información pública asociada al dominio de la organización IMF.

Esta herramienta permite obtener direcciones de correo electrónico, subdominios y hosts relacionados con la organización a partir de fuentes abiertas, como motores de búsqueda y servicios públicos.

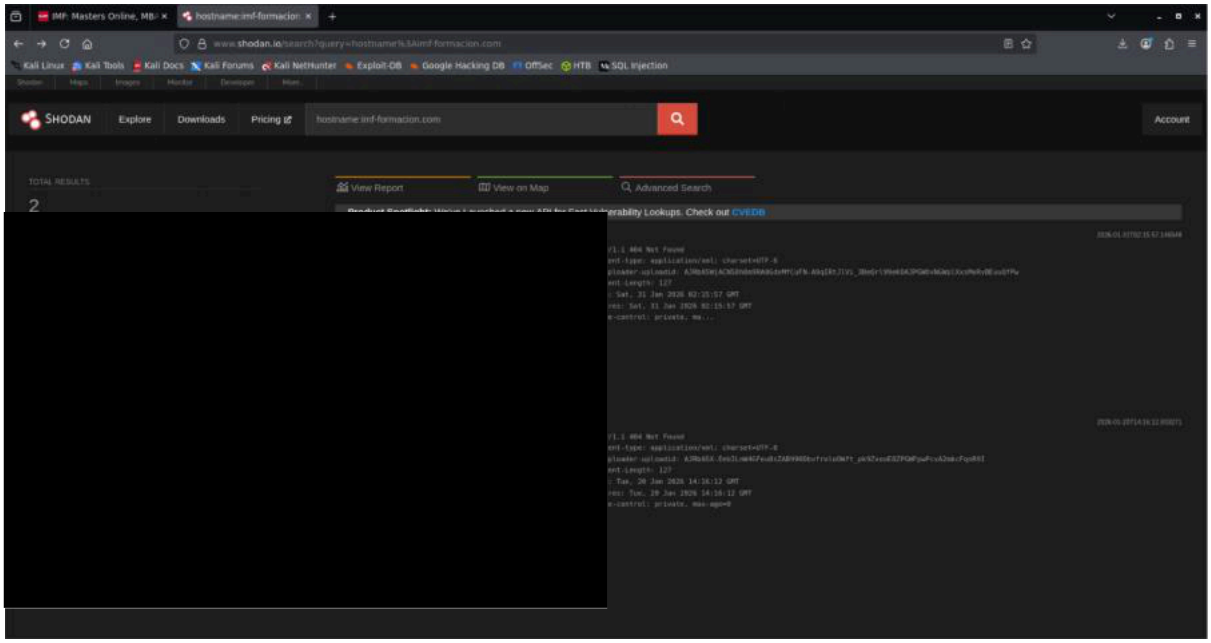


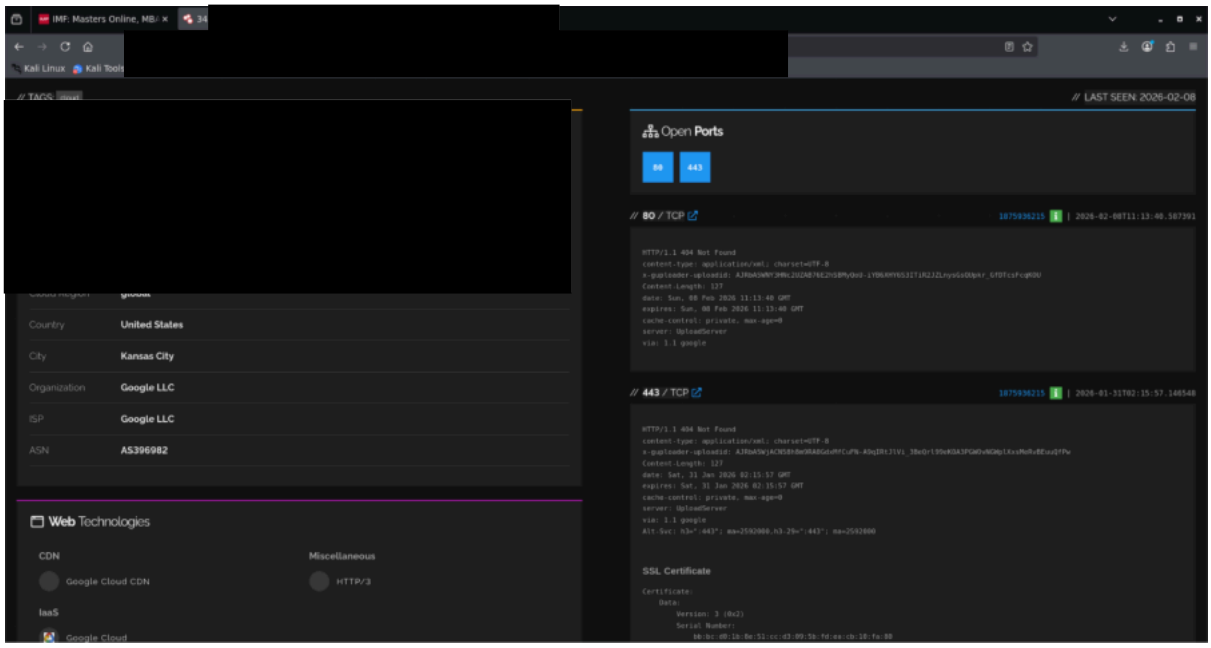
La herramienta Amass se ha utilizado con el objetivo de enumerar subdominios y activos asociados al dominio principal de IMF.

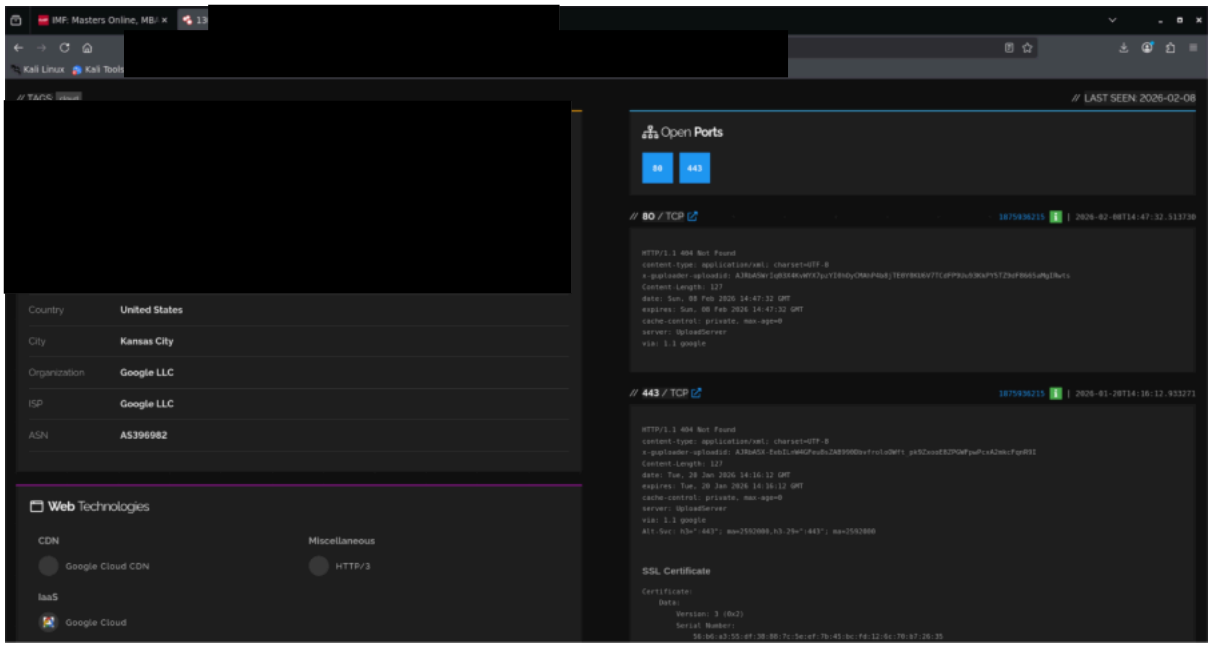
Amass permite recopilar información sobre la infraestructura de una organización utilizando fuentes abiertas, sin interactuar directamente con los sistemas objetivo, por lo que es adecuado para un análisis inicial no intrusivo.

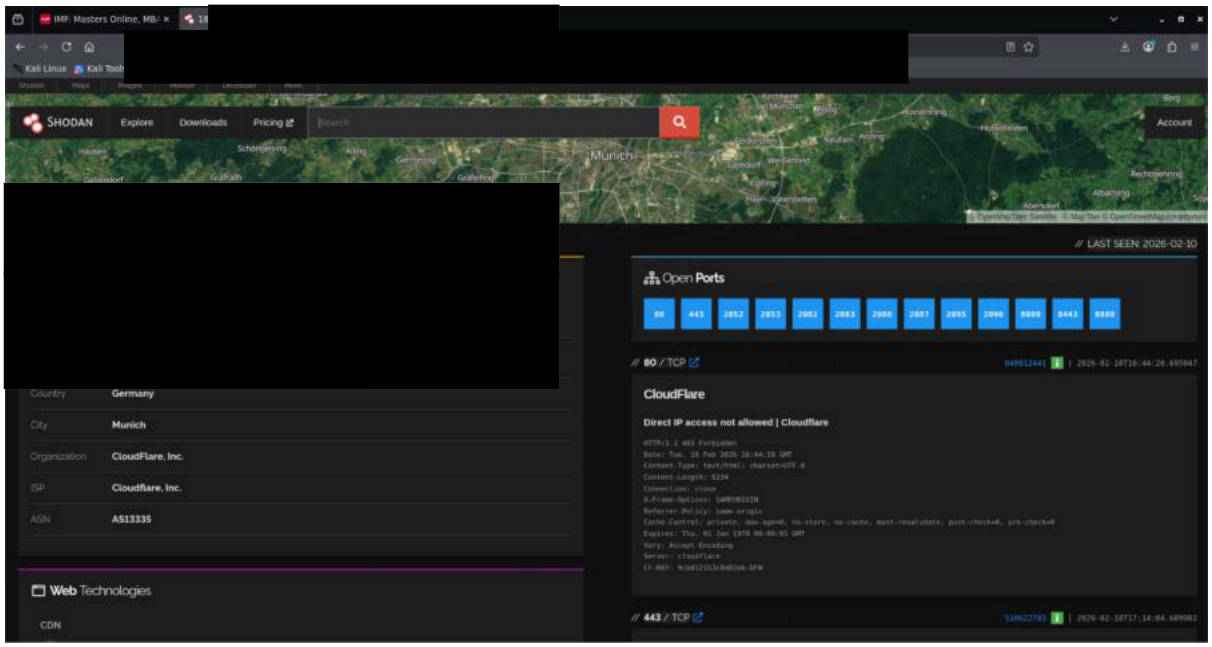
Búsqueda en Motores de IoT

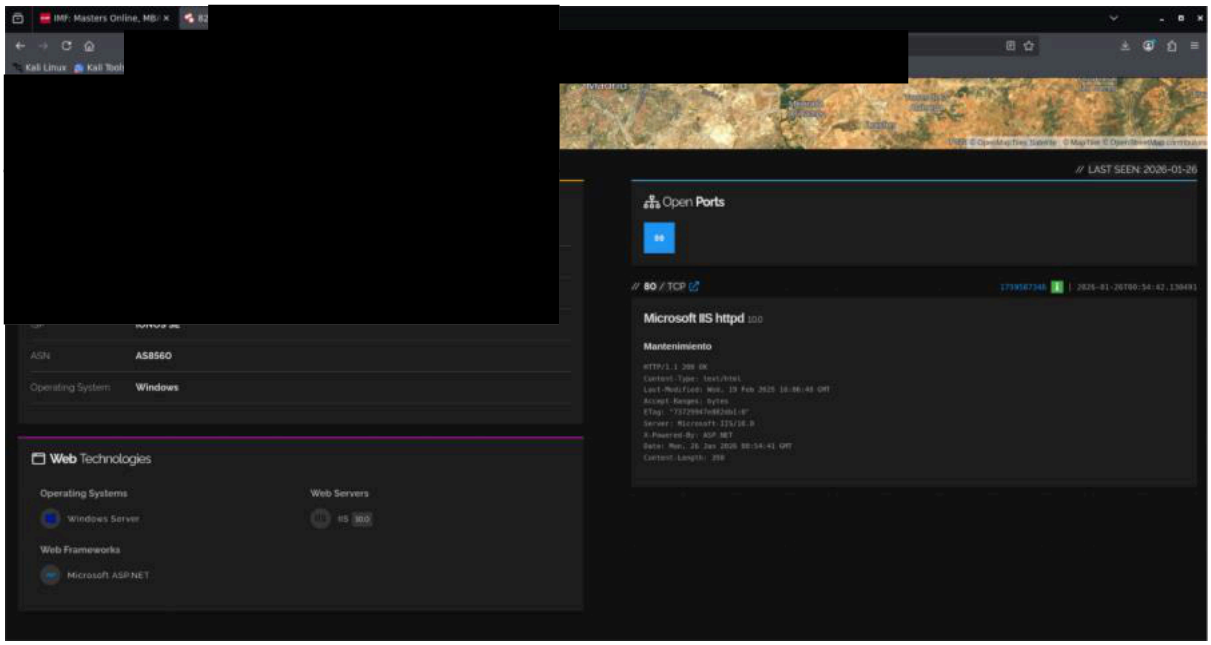
Se utiliza Shodan para identificar tecnologías, servidores y dispositivos expuestos a internet sin necesidad de enviar paquetes directamente a la víctima. A continuación, se ven diferentes ejemplos de búsquedas que se han hecho con dominios, subdominios, IPs, etc.

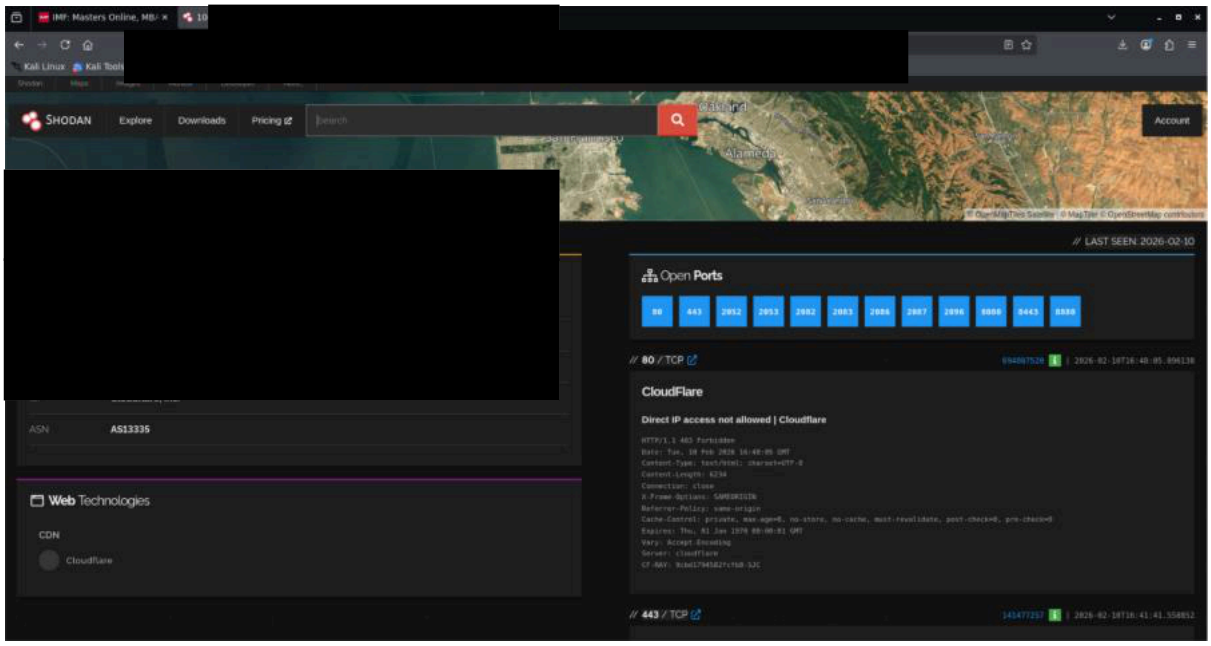

SHODAN
Explore
Downloads
Pricing
Account
View Report
View on Map
Advanced Search


Open Ports
80
443
Country
United States
City
Kansas City
Organization
Google LLC
ISP
Google LLC
ASN
AS396982
Web Technologies
CDN
Google Cloud CDN
Miscellaneous
HTTP/3
IaaS
SSL Certificate


Country United States
City Kansas City
Organization Google LLC
ISP Google LLC
ASN AS396982
Web Technologies
CDN
Google Cloud CDN
Miscellaneous
HTTP/3
IaaS
Google Cloud
Open Ports
80
443
// LAST SEEN: 2026-02-08
// 80 / TCP
// 443 / TCP
SSL Certificate


SHODAN
Explore
Downloads
Pricing
Search
Account
Munich
Country Germany
City Munich
Organization CloudFlare, Inc.
ISP Cloudflare, Inc.
ASN AS13335
Web Technologies
CDN
Open Ports
80
443
// LAST SEEN: 2026-02-10
// 80 / TCP
// 443 / TCP
CloudFlare
Direct IP access not allowed | Cloudflare


// LAST SEEN: 2026-01-26
Open Ports
80
// 80 / TCP
Microsoft IIS httpd 10.0
Mantenimiento
ASN AS8560
Operating System Windows
Web Technologies
Operating Systems
Windows Server
Web Servers
IIS 10.0
Web Frameworks
Microsoft ASP.NET


SHODAN
Explore
Downloads
Pricing
Account
// LAST SEEN: 2026-02-10
Open Ports
80 443 2052 2053 2082 2083 2086 2087 2096 8080 8443 8880
// 80 / TCP
CloudFlare
Direct IP access not allowed | Cloudflare
// 443 / TCP
ASN AS13335
Web Technologies
CDN
Cloudflare

Fase II: análisis y explotación en entorno controlado

Dado que no se dispone de autorización para realizar pruebas contra la organización real, se ha trabajado sobre una máquina virtual vulnerable preparada para este ejercicio.

El objetivo de esta fase fue simular un escenario real de intrusión controlada, siguiendo la metodología estándar:

- Escaneo de vulnerabilidades
- Verificación de falsos positivos
- Explotación
- Escalada de privilegios
- Obtención de flags

Identificación de la máquina víctima

Después de configurar el entorno con las máquinas virtuales en Host-only para permitir que ambas compartieran red, se realizó un escaneo de red para identificar la IP de la máquina vulnerable.

```
❯ nmap -sn 192.168.233.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-13 18:46 +0100
Nmap scan report for 192.168.233.1
Host is up (0.00089s latency).
MAC Address: 00:50:56:C0:00:01 (VMware)
Nmap scan report for 192.168.233.130
Host is up (0.00020s latency).
MAC Address: 00:0C:29:8C:CD:E1 (VMware)
Nmap scan report for 192.168.233.254
Host is up (0.00018s latency).
MAC Address: 00:50:56:E0:71:C4 (VMware)
Nmap scan report for 192.168.233.128
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 12.43 seconds
```

Sacamos la IP de la maquina victima con nmap.

- 192.168.233.128 - Máquina Kali
- 192.168.233.1 - Interfaz VMware
- 192.168.233.254 - Servicio interno del hipervisor
- 192.168.233.130 - Máquina víctima

Escaneo Detallado de Puertos

Una vez identificada la IP de la víctima, se realizó un escaneo más profundo.

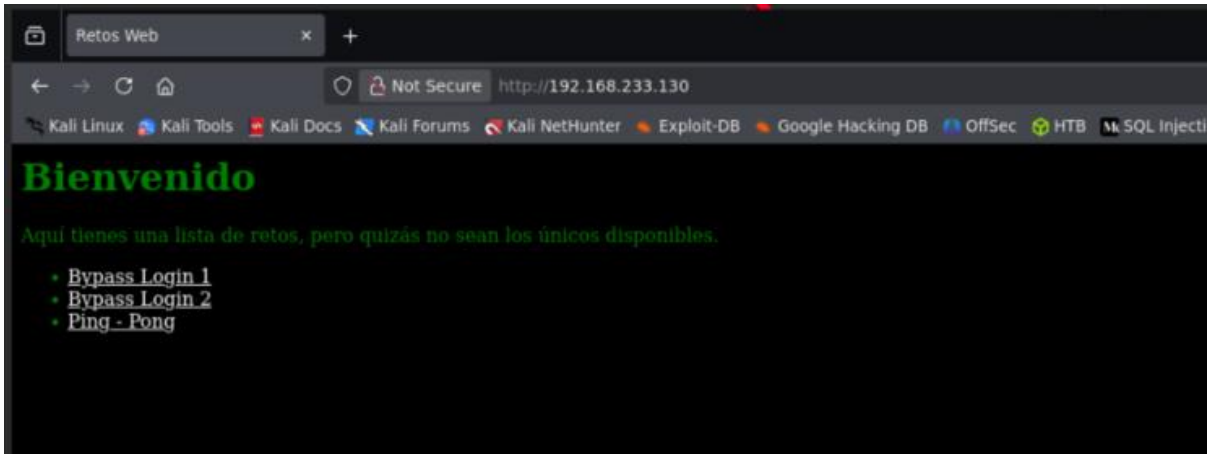
```
❯ nmap -sS -sC -sV -p- 192.168.233.130
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-13 18:57 +0100
Nmap scan report for 192.168.233.130
Host is up (0.00084s latency).
Not shown: 65528 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 3.0.3
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to ::ffff:192.168.233.128
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 2
|      vsFTPd 3.0.3 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--    1 ftp      ftp            30 Dec 07  2017 flag.txt
22/tcp   open  ssh         OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 d9:df:1b:29:5d:1e:3a:2e:9b:e0:11:2f:6a:21:00:39 (RSA)
|   256 90:0c:9a:0a:a2:f6:b6:c9:5e:f2:d8:9d:5f:f3:c7:f4 (ECDSA)
|_  256 d3:99:aa:5a:aa:25:b6:1f:47:e8:59:a5:c7:4e:95:8a (ED25519)
25/tcp   open  smtp        JAMES smtpd 2.3.2.1
|_smtp-commands: ubuntu Hello nmap.scanme.org (192.168.233.128 [192.168.233.128])
80/tcp   open  http        Apache httpd 2.4.18 ((Ubuntu))
|_http-title: Retos Web
|_http-server-header: Apache/2.4.18 (Ubuntu)
| http-robots.txt: 1 disallowed entry
|_/cyberacademy
110/tcp  open  pop3        JAMES pop3d 2.3.2.1
119/tcp  open  nntp        JAMES nntpd (posting ok)
4555/tcp open  james-admin JAMES Remote Admin 2.3.2.1
MAC Address: 00:0C:29:8C:CD:E1 (VMware)
Service Info: Host: ubuntu; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 167.07 seconds
```

Se hizo para identificar puertos abiertos, detectar servicios activos, conocer versiones y determinar posibles vectores de entrada.

Acceso al Servicio Web

Se accedió al navegador introduciendo “http://192.168.233.130”



El objetivo fue analizar manualmente la aplicación antes de lanzar herramientas automáticas. En esta fase se comenzó la exploración básica de:

- Directorios
- Enlaces
- Formularios
- Posibles rutas ocultas

Escaneo Semiautomático con Nikto

Se ejecutó la herramienta “nikto -h http://192.168.233.130”.

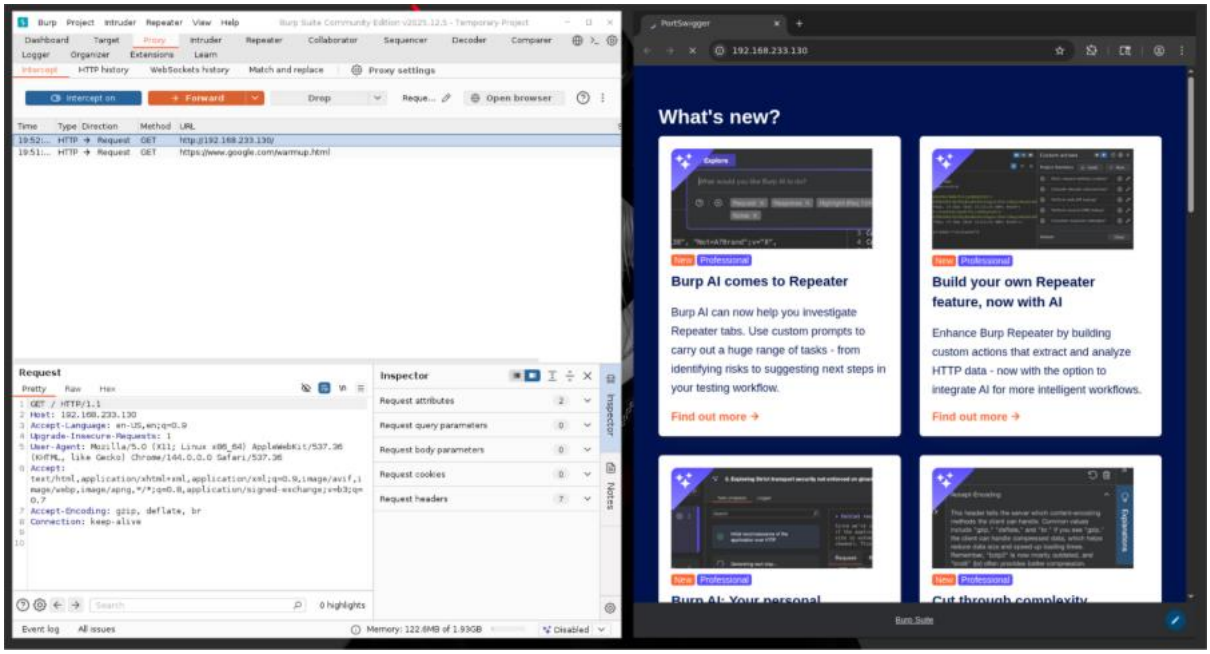


¿Por qué se utilizó?

Para obtener una visión de posibles vulnerabilidades web sin realizar explotación directa.

Análisis Manual con Burp Suite

Se configuró el navegador para interceptar tráfico HTTP mediante Burp Suite.



Con esta herramienta se analizaron parámetros enviados y http.

El objetivo era comprobar si la web era vulnerable a inyecciones, manipulación de parámetros y accesos no autorizados.

Obtención de la Flag 1

Durante la exploración inicial del servidor web se localizó un puerto abierto que corresponde a al servicio FTP.

Al intentar establecer conexión con el servidor FTP, se comprobó que permitía autenticación mediante el usuario anonymous sin contraseña.

Una vez dentro de FTP, se listó el contenido con ls y se identificó un archivo con el nombre de 'flag.txt'.

Se descargó el archivo en el sistema local con el comando 'get flag.txt'.

Y una vez en el sistema local, se visualizó el contenido con 'cat flag.txt'.

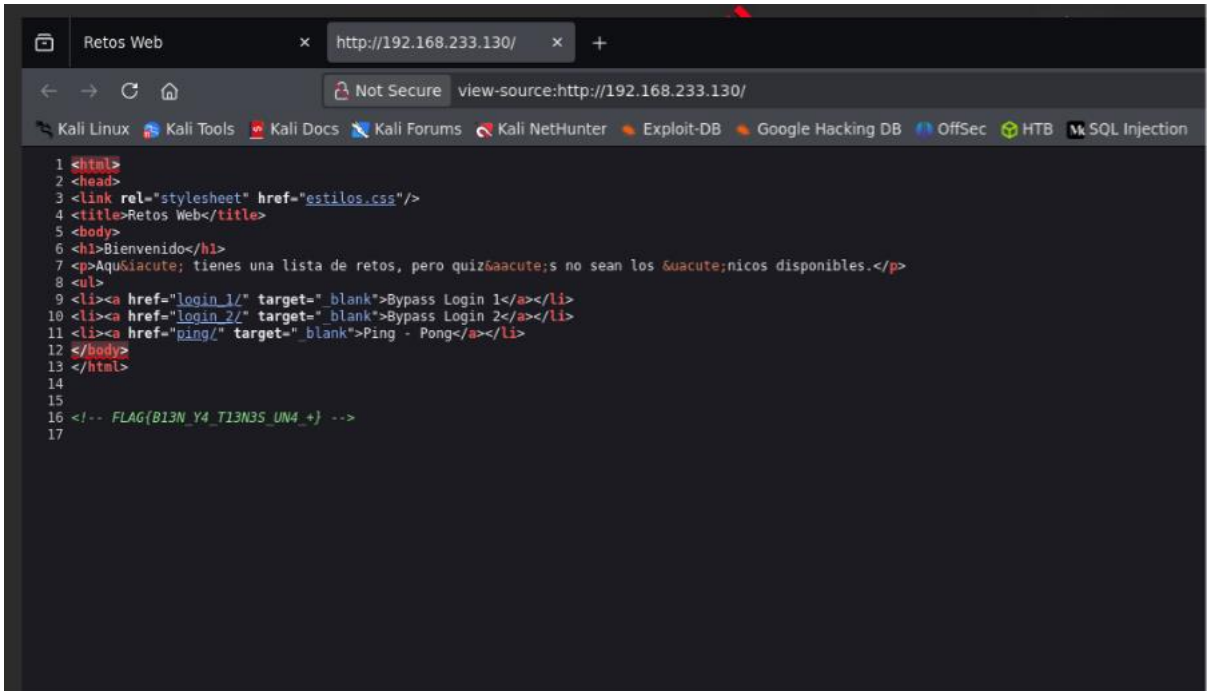


Vulnerabilidad identificada: Configuración insegura del servicio FTP

El servicio FTP permite autenticación anónima sin restricciones, lo que posibilita el acceso no autorizado a archivos alojados en el servidor.

Obtención de la Flag 2

Durante la exploración manual del servicio web, se revisó el código fuente de la página. En el HTML devuelto por el servidor se identificó una flag incluida dentro del código, aunque no visible en la interfaz web.

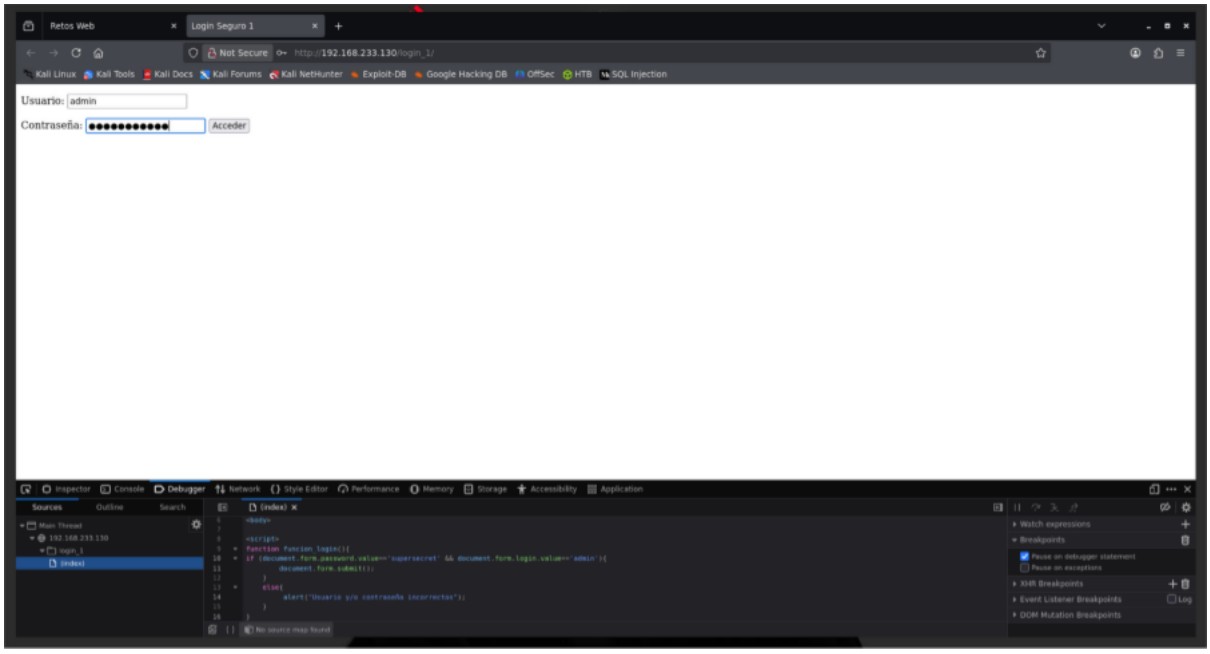


Vulnerabilidad identificada: Exposición de información sensible en el código fuente.

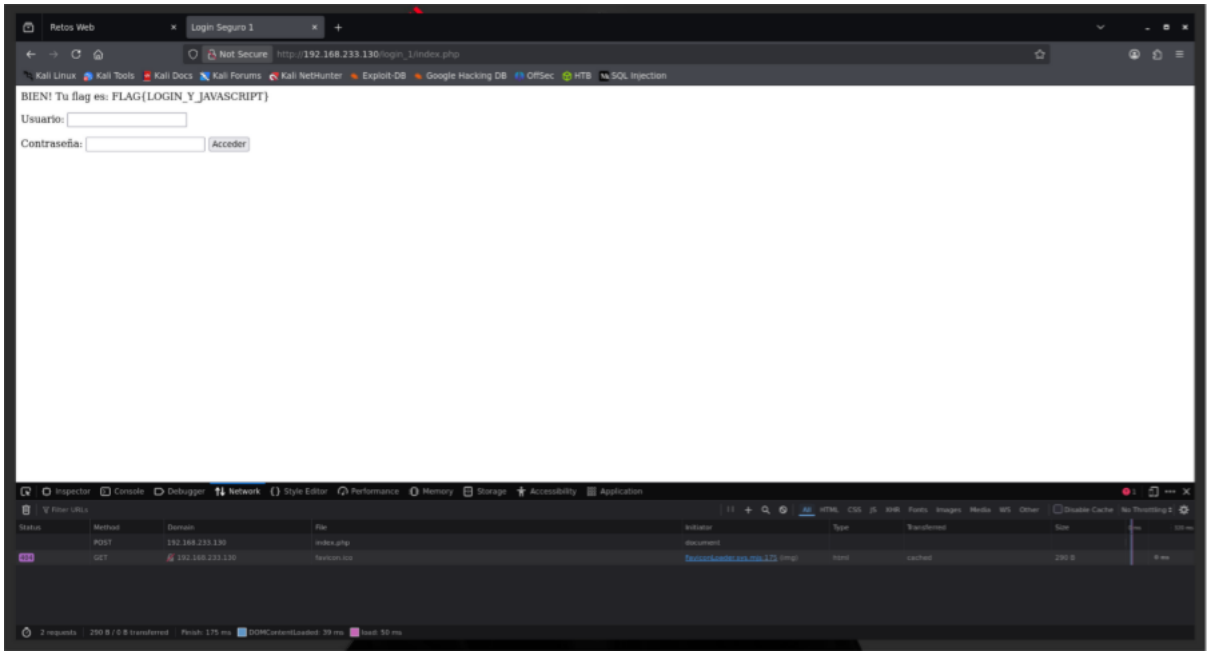
Obtención de la Flag 3

Durante el análisis del formulario de login, se inspeccionó el código JavaScript mediante las herramientas de desarrollador del navegador (F12).

En el script se identificaron las credenciales válidas en el código.



Al introducir dichas credenciales en el formulario, se obtuvo acceso y se localizó la flag.

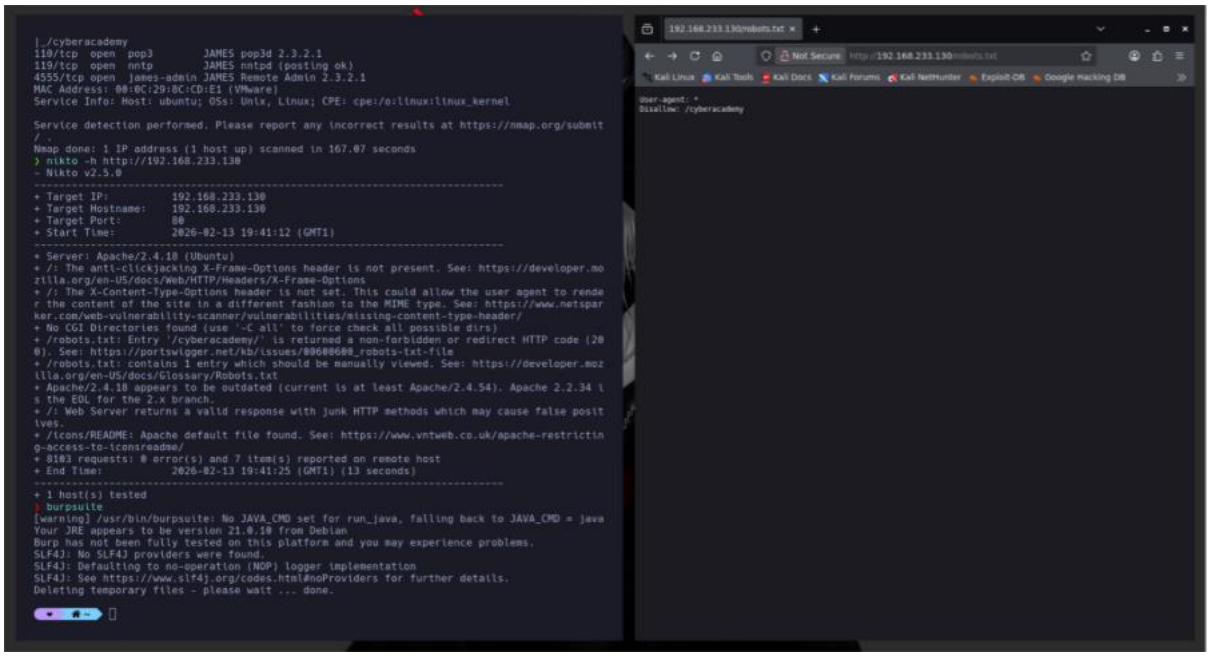


Vulnerabilidad identificada: Validación de autenticación en el lado cliente.

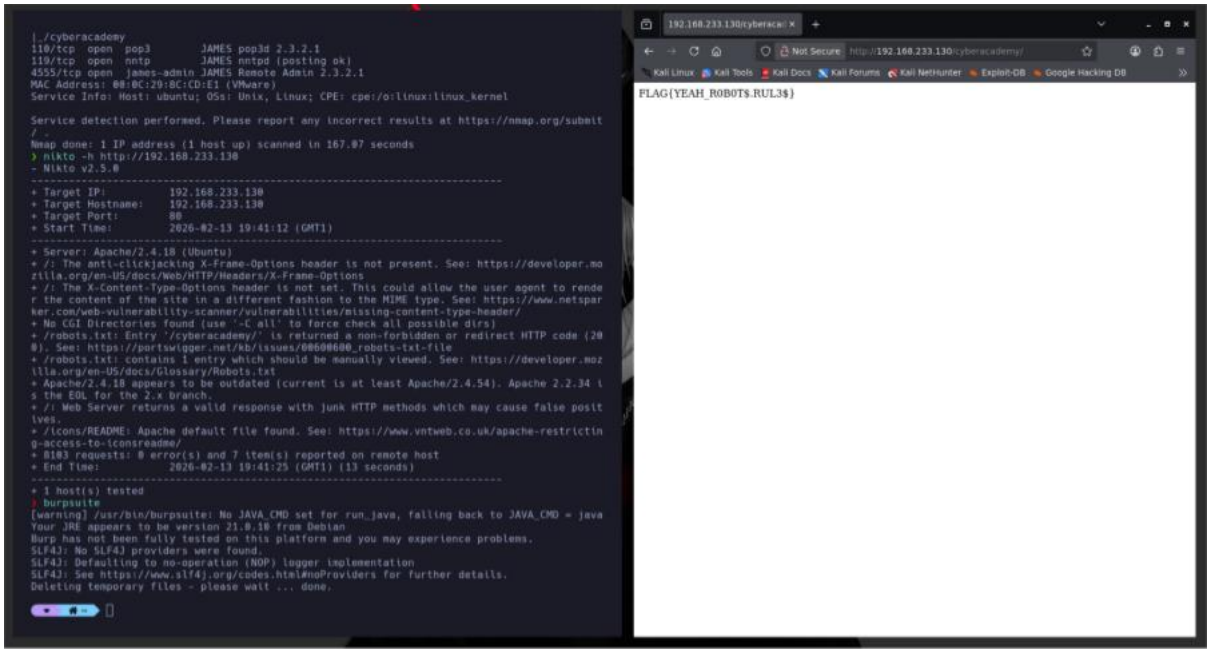
Obtención de la Flag 4

Durante la fase de enumeración del servidor web, se utilizó la herramienta Nikto para identificar posibles recursos expuestos. Se ejecutó el comando ‘nikto -h http://192.168.233.130’ y entre los resultados del escaneo, nikto detectó el archivo ‘/robots.txt’.

Se accedió desde el navegador a ‘http://192.168.233.130/robots.txt’.



Se identificó la ruta /ciberacademy/, por lo cual, se accedió a dicha ruta.



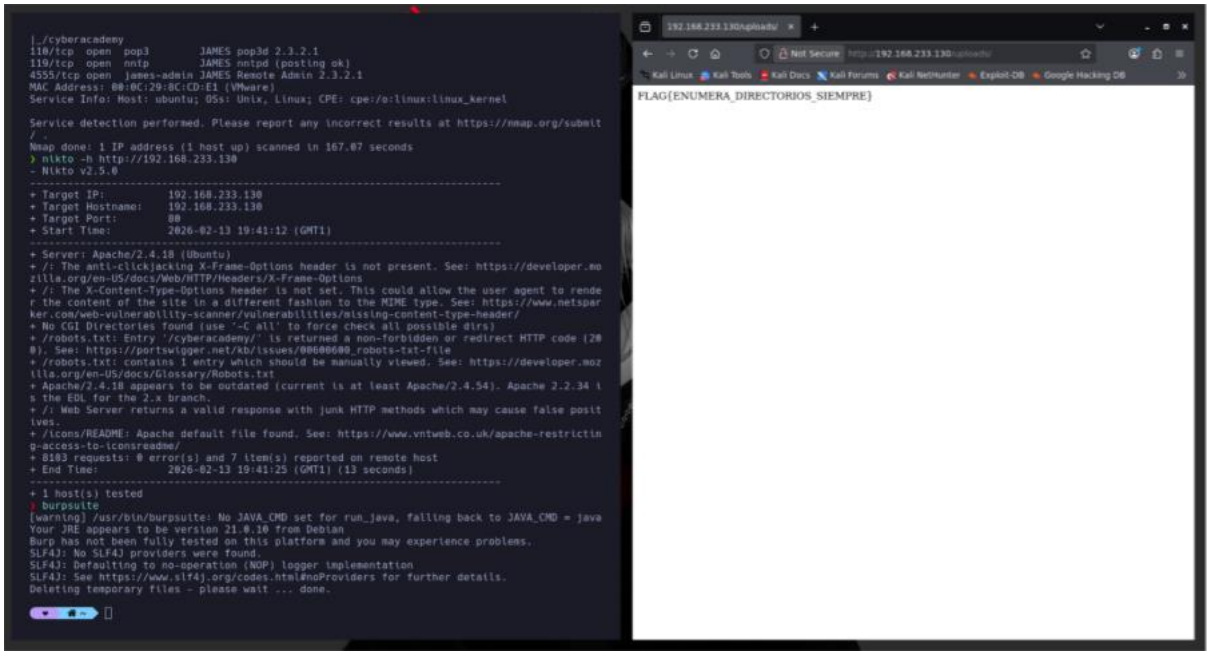
Vulnerabilidad identificada: Exposición de rutas sensibles mediante robots.txt

El archivo robots.txt contiene información sobre directorios internos accesibles públicamente. Aunque estos directorios no están enlazados desde la página principal, pueden ser accedidos mediante URL.

Obtención de la Flag 5

Durante la fase de enumeración del servidor web, se realizó la búsqueda de posibles directorios ocultos utilizando nombres comunes. Es decir, se probaron manualmente rutas habituales que suelen existir en aplicaciones, como /admin, /backup, /test, /updates, etc.

Al acceder desde el navegador a 'http://192.168.233.130/updates', se comprobó que el directorio existía y era accesible públicamente.



Vulnerabilidad identificada: Exposición de directorio no referenciado

El directorio /updates no estaba enlazado desde la página principal, pero era accesible directamente mediante URL

Obtención de la Flag 6

Durante la exploración de la aplicación web se identificó una funcionalidad accesible en la ruta 'http://192.168.233.130/ping/index.php', que permitía introducir una dirección IP para comprobar conectividad mediante el comando ping.

Para comprobar si existía una posible inyección de comandos, se modificó la URL de la siguiente forma:

http://192.168.233.130/ping/index.php?ip=127.0.0.1; ls

Como resultado, además del ping, se listaron los archivos del directorio actual en la propia página web.



Entre los archivos mostrados se encontraba 'estonoesunaflag.txt', que pudo visualizarse directamente en pantalla con el comando cat.



Vulnerabilidad identificada: Command Injection

Escalada de privilegios

Tras explotar la vulnerabilidad de inyección de comandos en la funcionalidad de ping, se obtuvo ejecución remota de comandos en el servidor con los privilegios del usuario web.

A partir de este acceso, se inició la fase de post-explotación con el objetivo de determinar si era posible elevar privilegios dentro del sistema.

Primero, se verificó el usuario con el que se estaban ejecutando los comandos.



Como parte del proceso de enumeración del sistema tras obtener ejecución de comandos, se realizó la búsqueda de binarios con el bit SUID activado mediante 'find / -perm -4000 2>/dev/null'

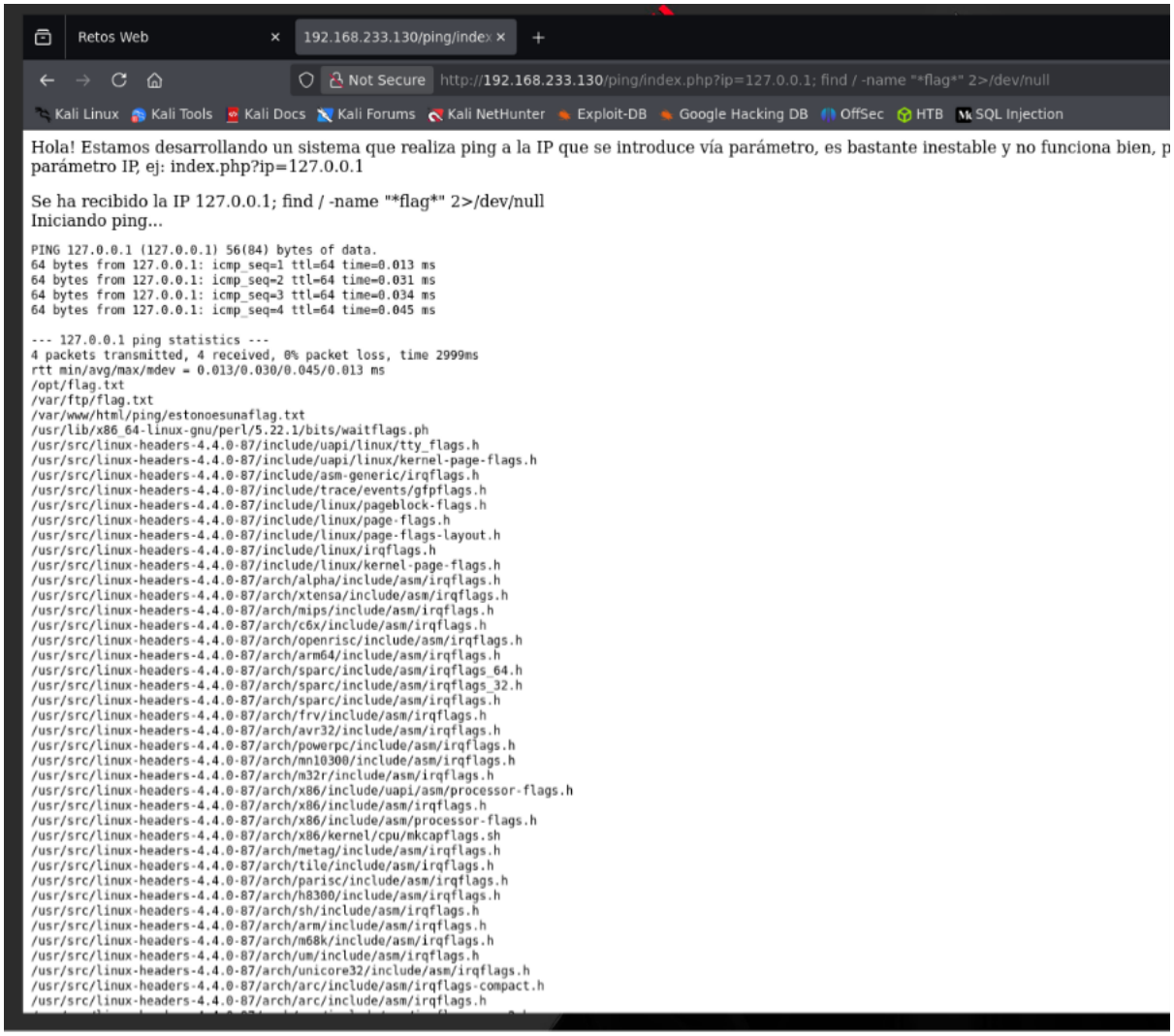


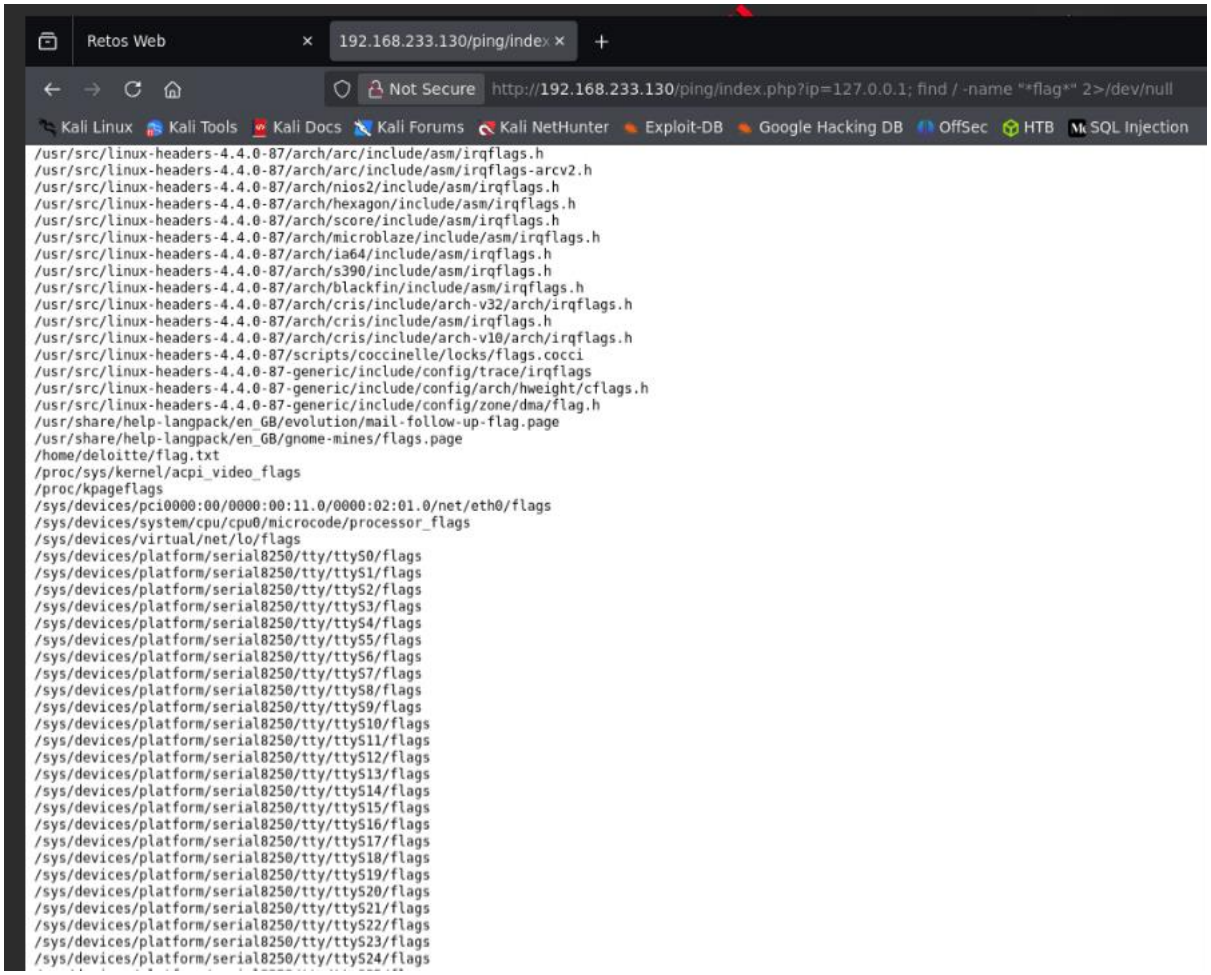
Este comando permite identificar archivos que se ejecutan con los privilegios de root, lo que puede suponer un vector de escalada de privilegios si alguno de ellos es vulnerable o está mal configurado.

Obtención de la Flag 7

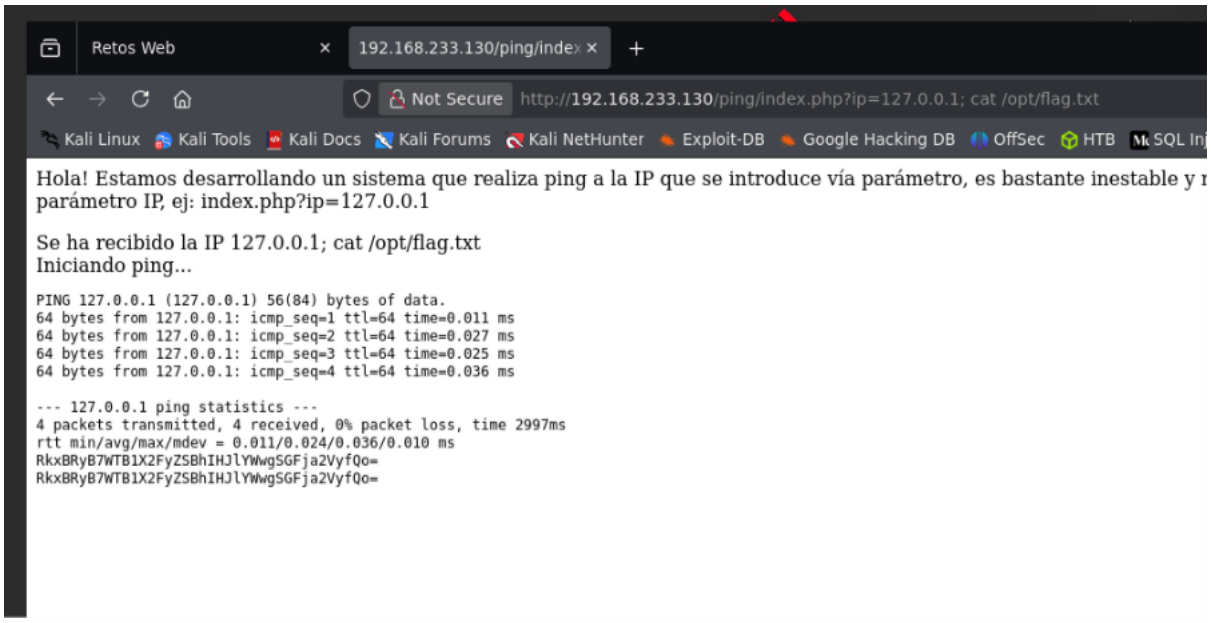
Una vez obtenidos privilegios de root, se procedió a explorar directorios del sistema que no eran accesibles con el usuario inicial.

Con la shell root activa, se comenzó la enumeración de directorios sensibles del sistema mediante el comando ‘find’, que permitió buscar con el nombre ‘flag’ para una búsqueda más rápida.

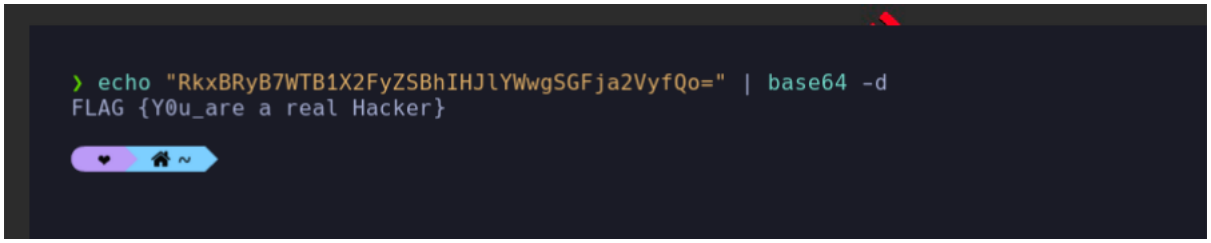




Al acceder a los directorios del usuario root, se localizó el archivo /opt/flag.txt, y mediante cat, se visualizó su contenido.



Al estar el texto en base64, lo decodificamos para ver el texto real de la flag.

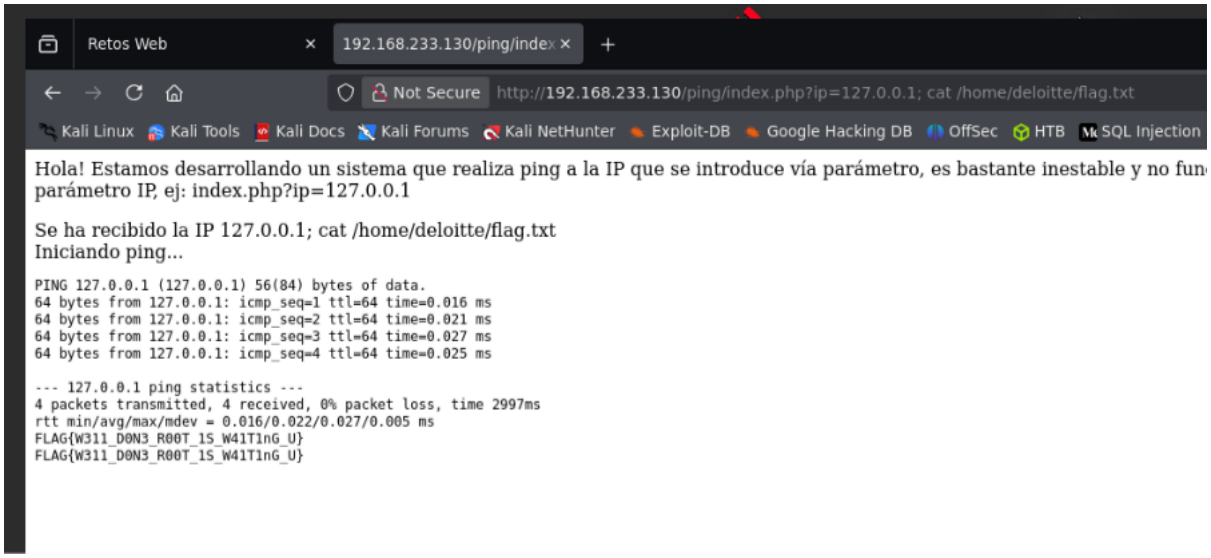


Vulnerabilidad identificada: Configuración insegura de sudo

Obtención de la Flag 8

La obtención de la Flag 8 viene a consecuencia de la explotación anterior para conseguir la Flag 7.

Como se mostraron diferentes archivos .txt con el nombre de flag, mediante el comando cat se visualizó el siguiente, en la ruta /home/deloitte/flag.txt



Vulnerabilidad identificada: Configuración insegura de sudo

Obtención de la Flag 9

Tras completar la escalada de privilegios y obtener acceso como root, se procedió a revisar el directorio root en busca de posibles evidencias.

Con la shell root activa, se accedió al directorio /root, que solo es accesible por el superusuario con el comando ‘cd /root’.

Una vez dentro, se listaron los archivos disponibles con ls y se identificó el archivo ‘flag.txt’.

Finalmente, se visualizó su contenido mediante ‘cat /root/flag.txt’.



Esta flag no representa una nueva vulnerabilidad.

Su obtención fue posible a la explotación de la mala configuración de sudo que permitió obtener privilegios de root.

Sin acceso root, el directorio /root no es accesible para usuarios estándar.

Conclusión

Resumen Ejecutivo

Durante la presente auditoría de seguridad sobre la máquina virtual, se ha llevado a cabo un análisis estructurado siguiendo la metodología del hacking ético, comenzando por fases de reconocimiento y enumeración, y finalizando con explotación y post-explotación del sistema.

A lo largo del proceso se identificaron múltiples vulnerabilidades que permitieron comprometer el entorno hasta alcanzar el control total del sistema.

Principales hallazgos

Durante el análisis se detectaron las siguientes debilidades críticas:

- Exposición de información sensible en el código fuente de la aplicación web.
- Descubrimiento de directorios ocultos mediante análisis de robots.txt.
- Acceso no autenticado a servicios (FTP anónimo).

- Vulnerabilidad de inyección de comandos (Command Injection) en la funcionalidad de ping.
- Acceso completo al sistema tras la escalada de privilegios.

Esto permitió:

- Obtener ejecución remota de comandos.
- Escalar privilegios hasta root.
- Acceder a directorios restringidos del sistema.
- Comprometer completamente la máquina.

Conclusión General

La máquina virtual presenta múltiples fallos de configuración y vulnerabilidades que permiten su compromiso total sin necesidad de credenciales válidas.

Este ejercicio evidencia la importancia de realizar auditorías periódicas de seguridad y corregir vulnerabilidades antes de que puedan ser explotadas.